



Handle Identity on the AT Protocol



From Auth0 to Decentralized Sign-In on Aesthetic Computer

ATProto OAuth, Handle Verification, and Portable Creative Identity

@jeffrey

Aesthetic.Computer

ORCID: 0009-0007-4460-4913

<https://aesthetic.computer>

[working draft — not for citation]

Abstract. Aesthetic Computer currently authenticates users through Auth0 and maintains a parallel identity on a self-hosted AT Protocol Personal Data Server (PDS) at at.aesthetic.computer. Each verified user receives a DID and a PDS handle, but authentication flows through a centralized OAuth provider. We propose collapsing this dual-identity architecture by adopting AT Protocol OAuth (?) as a primary sign-in method, allowing anyone with a Bluesky or ATProto identity to authenticate directly and claim the equivalent handle on Aesthetic Computer. This paper surveys the AT Protocol identity stack—DIDs, handle verification, OAuth 2.1 with DPoP and PAR—examines how pckt.blog and other ATProto-native applications implement decentralized sign-in (?), maps the current AC authentication architecture, and proposes a phased migration from Auth0 dependency to AT Protocol-first identity. The central argument: on a platform that already runs its own PDS and mints its own DIDs, the centralized identity provider is the vestigial organ. Removing it simplifies the stack, eliminates a paid dependency, and makes AC a first-class citizen of the federated social web. I extend this argument to AC Native OS (?): a bare-metal laptop that carries its own PDS is not a client—it is a sovereign node on the ATProto network, capable of offline-first content creation and device-to-device federation without cloud dependency.

1. INTRODUCTION

Identity on the web is a landlord problem. You do not own your handle on Twitter, your username on Instagram, or your login on any platform that can delete your account. The AT Protocol (?)—the decentralized social networking protocol behind Bluesky—proposes a different arrangement: your identity is a cryptographic key pair, your handle is a domain name you control, and your data lives on a Personal Data Server that you can move between providers.

Aesthetic Computer has operated a hybrid identity system since 2024. Auth0 (?) handles authentication: OAuth 2.0 with PKCE, refresh tokens, and a managed user database. Separately, a self-hosted PDS at `at.aesthetic.computer` mints ATProto identities for every verified user. The result is a doubled system: two identities per user, two credential stores, two handle sync paths, and a paid Auth0 subscription bridging the gap.

This paper asks: what if the PDS *is* the identity provider?

The answer is not hypothetical. `pckt.blog` (?), a blogging platform built on the AT Protocol, authenticates users entirely through AT Protocol OAuth. Users sign in with their Bluesky handle, their self-hosted PDS, or any compatible identity provider. No Auth0, no Firebase, no centralized user database. The content syncs to the user's own PDS using shared lexicons from `Standard.site` (?).

We examine how this model applies to Aesthetic Computer—a creative computing platform with 600+ interactive pieces, multiplayer sessions, a KidLisp programming language, and a native bare-metal OS (?)—and propose a phased migration that preserves backward compatibility while moving toward decentralized identity.

2. CURRENT ARCHITECTURE

2.1 Auth0 as Identity Provider

Authentication flows through Auth0's SPA SDK. On page load, `boot.mjs` checks `localStorage` for cached Auth0 state. If a session exists (or an OAuth callback is detected), it initializes the Auth0 client with PKCE and refresh tokens, exchanges authorization codes for access tokens, and retrieves the user profile. The Auth0 sub field (e.g., `auth0|abc123` or `google-oauth2|xyz`) serves as the internal user identifier.

```
// boot.mjs: current Auth0 flow
const auth0 = await createAuth0Client({
  domain: "hi.aesthetic.computer",
  clientId: "LVdZaM...",
  cacheLocation: "localStorage",
  useRefreshTokens: true,
});
const user = await auth0.getUser();
```

```
// { sub, email, email_verified, ... }
```

2.2 Handle System

Handles are stored in a MongoDB `@handles` collection, mapping Auth0 sub to a 1–16 character alphanumeric string (with `.` and `_` allowed). Validation enforces no leading/trailing punctuation, case-insensitive uniqueness, and profanity filtering. Handles are the primary user-facing identity: URL-addressable (`@handle/piece-name`), visible in chat, and spoken aloud by AC Native OS.

2.3 ATProto Shadow Identity

On first email verification, an Auth0 webhook triggers `createAtprotoAccount()`, which:

1. Generates a 32-character password
2. Creates an invite code on the PDS
3. Creates an account at `handle.at.aesthetic.computer`
4. Stores the DID, handle, and encrypted password in MongoDB (`users.atproto`)

When a user changes their AC handle, `updateAtprotoHandle()` syncs the change to the PDS. Content (paintings, moods, KidLisp snippets, tapes, news) is mirrored to the PDS via six custom lexicons (`computer.aesthetic.*`). The ATProto identity is real and functional—but the user never authenticates through it. It is a shadow identity: present, synced, but not sovereign.

2.4 The Duplication Problem

This architecture means:

- Two credential stores (Auth0 + PDS)
- Two handle namespaces (AC handles + PDS handles)
- Two sync paths (handle changes propagate Auth0 → MongoDB → PDS)
- A paid dependency (Auth0 subscription)
- No interoperability (a Bluesky user cannot sign into AC with their existing identity)

The PDS already knows who each user is. It already stores their DID, their handle, their content. The Auth0 layer adds cost and complexity without adding capability that the PDS cannot provide.

3. THE AT PROTOCOL IDENTITY STACK

Understanding the migration requires understanding the three layers of AT Protocol identity: DIDs, handles, and OAuth.

3.1 Decentralized Identifiers (DIDs)

A DID (??) is a persistent, cryptographically verifiable identifier. The AT Protocol primarily uses `did:plc`, a method designed for strong consistency, high availability, and key rotation without losing identity. Each DID

resolves to a document containing:

- A **signing key** (P-256 or K-256) (?) for authenticating repository updates
- **Rotation keys** for account recovery
- A **PDS endpoint URL**
- The user's current **handle**

The DID is the stable identity. Handles change; keys rotate; PDS providers come and go. The DID persists. AC already mints DIDs for every user through its PDS. The infrastructure exists.

3.2 Handle Verification

An AT Protocol handle (?) is a domain name that bidirectionally resolves to a DID. Verification uses two methods:

DNS TXT: Place a record at `_atproto.example.com`:

```
_atproto.example.com TXT "did=did:plc:abc..."
```

HTTPS Well-Known: Serve the DID at:

```
GET /.well-known/atproto-did
Response: did:plc:abc...
```

Both methods require the handle to resolve to the DID *and* the DID document to claim the handle back. This bidirectional verification means: if you control the domain, you control the handle. No central authority assigns handles; DNS is the authority.

For AC, this means `jeffrey.at.aesthetic.computer` is a real, verifiable ATProto handle because AC controls both the DNS and the PDS. But it also means a user who already owns `alice.bsky.social` or `alice.dev` has a cryptographically verified identity that AC can trust without a password.

3.3 ATProto OAuth

The AT Protocol OAuth specification (?) extends OAuth 2.1 with three mandatory security mechanisms:

PKCE (Proof Key for Code Exchange) (?): Prevents authorization code interception. The client generates a random verifier, sends its hash with the authorization request, and proves possession of the original verifier during token exchange.

PAR (Pushed Authorization Requests) (?): The client submits authorization parameters via POST to the authorization server *before* redirecting the user. This prevents parameter tampering in the redirect URL.

DPoP (Demonstrating Proof of Possession) (?): Each request includes a signed JWT proving the client holds the private key associated with the token. Even if an access token leaks, it cannot be used by a different client.

3.3.1 Client Identification

Unlike traditional OAuth, AT Protocol does not require pre-registration with each authorization server. Instead, clients publish metadata at a public HTTPS URL:

```
// aesthetic.computer/oauth/client-metadata.json
{
  "client_id": "https://aesthetic.computer/...",
  "client_name": "Aesthetic Computer",
  "redirect_uris": ["https://..."],
  "grant_types": ["authorization_code"],
  "dpop_bound_access_tokens": true
}
```

Any PDS can discover and verify the client by fetching this URL. No pre-shared secrets, no app store registration, no API key management.

3.3.2 The Flow

1. User enters their handle (e.g., `alice.bsky.social`)
2. Client resolves handle → DID → PDS endpoint → authorization server
3. Client pushes authorization parameters via PAR
4. User is redirected to their PDS's authorization UI
5. User approves; PDS redirects back with authorization code
6. Client exchanges code for DPoP-bound access token
7. Client verifies the returned DID matches the expected identity

The critical difference from Auth0: the user authenticates with *their own server*. AC never sees a password. The PDS—whether Bluesky's, AC's own, or a self-hosted instance—is the identity authority.

4. CASE STUDY: PCKT.BLOG

`pckt.blog` (?) is a blogging platform that authenticates exclusively through AT Protocol OAuth. Its implementation demonstrates the practical viability of ATProto-only authentication for a content platform.

4.1 Authentication

Users sign in by entering their ATProto handle. `pckt.blog` resolves the handle, discovers the authorization server, and initiates the OAuth flow. The user approves on their PDS (Bluesky, Blacksky, a self-hosted server). `pckt.blog` receives a DPoP-bound access token and the user's DID. No passwords are stored. No separate user database is maintained.

4.2 Data Sovereignty

Content syncs to the user's own PDS using `Standard.site` lexicons (?):

- `site.standard.publication` — blog collections
- `site.standard.document` — individual articles

- `site.standard.graph.subscription` — follow relationships

If `pckt.blog` disappears, the user’s content remains on their PDS, accessible to any compatible reader. This is the promise of ATProto: the platform is a view, not a silo.

4.3 Implications for AC

`pckt.blog` proves that a content-oriented platform can operate entirely on ATProto identity. The parallels to AC are direct:

- `pckt.blog` publishes articles; AC publishes pieces, paintings, and moods
- `pckt.blog` uses `Standard.site` lexicons; AC has six custom `computer.aesthetic.*` lexicons
- `pckt.blog`’s users own their content on their PDS; AC already mirrors content to its PDS
- Both are Node.js/JavaScript applications

The gap: `pckt.blog` was built ATProto-native. AC has an existing Auth0 user base that must be migrated gracefully.

5. PROPOSED MIGRATION

5.1 Phase 1: ATProto OAuth as Secondary Sign-In

Add “Sign in with Bluesky” alongside Auth0, without removing Auth0.

Infrastructure:

1. Publish client metadata at `aesthetic.computer/oauth/client-metadata.json`
2. Add `@atproto/oauth-client-node (?)` to the backend
3. Create two new Netlify functions:
 - `POST /api/atproto-auth/start` — resolve handle, PAR, redirect
 - `GET /api/atproto-auth/callback` — code exchange with DPoP
4. Store sessions in Redis (DID, handle, DPoP key pair, tokens)

Client flow: A new “Sign in with Bluesky” button in `boot.mjs` triggers the ATProto OAuth flow. On success, `window.acUSER` is populated from the ATProto session (DID as sub, handle, no email unless the user provides one). The piece API surface is identical—pieces see a user with a handle, regardless of which auth path created the session.

5.2 Phase 2: Handle Bridging

When a user signs in via ATProto, bridge their handle to AC:

1. Extract the username from the ATProto handle (e.g., `alice` from `alice.bsky.social`)
2. Check availability against the AC `@handles` collection
3. If available and valid (1–16 chars, alphanumeric), offer one-click claim

4. If taken, check if the existing owner’s email matches—offer account linking
5. If taken by someone else, prompt for an alternative
6. Store a DID ↔ AC sub mapping in MongoDB for future sign-ins

Custom domain handles (e.g., `alice.dev`) require the user to choose an AC handle manually, since the domain itself may not map to a valid handle string.

5.3 Phase 3: Identity Linking

Existing Auth0 users can link their ATProto identity:

1. From account settings, initiate ATProto OAuth
2. On success, store the external DID alongside the Auth0 sub
3. Future sign-ins accept either auth path
4. Content can optionally sync to the user’s external PDS (not just AC’s PDS)

This phase turns the existing `users.atproto` field from a shadow identity into a first-class identity link.

5.4 Phase 4: ATProto-Primary

Once the migration is validated:

1. New signups default to ATProto OAuth (creating accounts on AC’s PDS)
2. Auth0 remains as a legacy path for existing users
3. Gradually sunset Auth0 as users link their ATProto identities
4. Remove Auth0 dependency, eliminate subscription cost

5.5 PDS Routing

A key architectural decision: where does content go?

- **Auth0-only users:** content syncs to AC’s PDS (current behavior)
- **ATProto users with external PDS:** content syncs to *their* PDS
- **ATProto users on AC’s PDS:** content stays on AC’s PDS

This means the backend sync functions (`media-atproto.mjs`, `painting-atproto.mjs`, etc.) need a conditional path: resolve the user’s PDS endpoint from their DID document, and write to that endpoint rather than assuming AC’s PDS.

6. HANDLE SEMANTICS

The handle is the most human-visible piece of the identity stack, and the migration raises questions about what a handle *means*.

6.1 Current Handle Model

Today, an AC handle is:

- A 1–16 character string, first-come-first-served
- Unique within the AC namespace

- Used for URLs (@alice/painting), chat, and OS personalization
- Stored in MongoDB, cached in Redis
- Mirrored to the PDS as `alice.at.aesthetic.computer`

6.2 ATProto Handle Model

An ATProto handle is:

- A domain name (any valid DNS name)
- Verified bidirectionally against a DID
- Globally unique by DNS authority
- Portable across services

6.3 Bridging the Models

The proposal: an AC handle is an *alias* that maps to a DID. The source of truth shifts from MongoDB to the DID layer. Multiple sign-in methods (Auth0, ATProto OAuth) resolve to the same DID, which resolves to the same AC handle.

For AC Native OS (?), where the handle is inscribed in `config.json` on the boot partition, this means the device identity is backed by a cryptographic identity. “Hi @alice” on the boot screen means Alice’s DID, Alice’s signing key, Alice’s portable identity—not just a string in a config file.

7. OPEN QUESTIONS

Handle priority. If `alice` is unclaimed on AC but `alice.bsky.social` signs in, should she get it automatically? First-come-first-served is simple but allows squatting. ATProto-verified priority is fairer but adds complexity.

Email requirement. Auth0 provides verified email for account recovery. ATProto OAuth does not guarantee email. Should AC require an email for full account features (purchasing, notifications)?

Multi-tenant. AC operates a second tenant (`sotce`) with separate Auth0. How do ATProto identities map across tenants? The DID is tenant-agnostic, which may simplify cross-tenant identity.

Session server. Real-time features (chat, multiplayer) authenticate via Auth0 tokens forwarded through WebSocket. The session server must accept ATProto-issued tokens or a unified session token.

Device pairing. AC Native OS pairs via a 6-character code exchanged through Auth0. The ATProto equivalent: scan a QR code that initiates an OAuth flow on the phone, delivering tokens to the device.

Admin identity. Admin is currently `handle === "jeffrey" && sub === ADMIN_SUB`. Under ATProto-first auth, admin is `did === admin_did`—cleaner, cryptographically grounded.

8. RELATED WORK

Decentralized identity. The W3C DID specification (?) provides the formal framework for decentralized identifiers. The AT Protocol’s `did:plc` method (?) extends this with strong consistency guarantees and a centralized-but-auditable directory at `plc.directory`. This is a pragmatic compromise: full decentralization of identity resolution remains an open problem, and `did:plc` trades some decentralization for operational reliability.

ATProto-native applications. `pckt.blog` (?) demonstrates blogging; `Leaflet.pub` and `Offprint.app` collaborate on shared lexicons via `Standard.site` (?). These applications prove the viability of ATProto-only auth for content platforms.

OAuth security. DPoP (?) prevents token theft; PAR (?) prevents parameter tampering; PKCE (?) prevents code interception. Together they represent the state of the art in browser-based OAuth security—significantly stronger than the Auth0 SPA flow AC currently uses.

Convivial identity. Illich’s tools for conviviality (?) frame the question: does the identity system expand personal autonomy, or does it require dependence on a provider? Auth0 is a managed service—convenient but dependent. ATProto identity is portable, self-verifiable, and provider-independent. Nelson’s vision of personal computing (?) extends naturally to personal identity: you should own your name on the network.

9. PDS ON BARE METAL

AC Native OS (?) boots any x86_64 machine into a creative computing instrument in 7.3 seconds. The device already carries an identity: a handle inscribed in `config.json` on the boot partition, spoken aloud at startup (“hi @alice”), and used to authenticate with the session server. But this identity is a string in a file. It is not cryptographically grounded. It is not portable. It is not verifiable by anyone outside the AC ecosystem.

Running a PDS on the device changes this.

9.1 Architecture

The AC OS runtime is a single C binary (PID 1) that launches a QuickJS JavaScript engine. Adding a PDS means adding a second process: a lightweight ATProto-compatible server that manages the device owner’s identity, stores their content locally, and federates with the broader ATProto network when connected to the internet.

The components:

- **Local PDS:** A minimal ATProto server running on localhost, storing repository data in SQLite on the boot partition. The device’s DID document points to this PDS when online, or to a relay when offline.
- **DID:** The device owner’s `did:plc` identity, with sign-

ing keys stored on the boot partition. The same DID that works on Bluesky, on AC’s cloud PDS, and on any other ATPProto service.

- **Handle:** `alice.at.aesthetic.computer` resolves to the device’s DID whether the device is online or not—DNS handles are verified against the PDS, not against the device.
- **Offline-first content:** Paintings, KidLisp programs, and notepad recordings are written to the local PDS repository. When the device connects to WiFi, it syncs upstream—to AC’s relay, to Bluesky’s firehose, to any subscribed service.

9.2 What This Means

A laptop that carries its own PDS is not a client. It is a node. The device does not depend on AC’s servers to know who its owner is—the signing keys are on the boot partition, the DID is resolvable, and the content is stored locally. If AC’s cloud infrastructure disappears tomorrow, the device still knows its owner, still stores their work, and still has a cryptographically verifiable identity on the ATPProto network.

This is a synthesis. Booting the laptop *is* logging in. The device knows your DID because your signing keys are on the boot partition. The OS greeting (“hi @alice”) is not a decorative string—it is a cryptographic assertion of identity. There is no separate login screen, no OAuth redirect, no password prompt. The act of turning on the machine authenticates you to the ATPProto network, because the machine *is* your PDS.

This collapses three traditionally separate concepts—device ownership, application identity, and network identity—into one. The person who flashed the USB drive owns the signing keys. The signing keys prove the DID. The DID resolves to the handle. The handle is spoken aloud at boot. Identity is not a service you log into. It is a property of the hardware you hold.

9.3 Implementation Path

The path is incremental:

1. **Phase 1:** Device pairs with AC cloud PDS (current behavior). Identity lives in the cloud; device has a copy of the handle in `config.json`.
2. **Phase 2:** Device runs a local PDS that mirrors the cloud PDS. Content is written locally first, synced when online. Identity is still managed by the cloud PDS.
3. **Phase 3:** Device PDS becomes authoritative. The DID document points to the device’s PDS as the primary endpoint. The cloud PDS is a relay, not the source of truth.
4. **Phase 4:** Device-to-device federation. Two AC OS laptops on the same WiFi network discover each other’s PDS and exchange content directly, without routing through the cloud.

Phase 4 is the most interesting for the PLOrk-derived classroom scenario described in the companion paper (?). Thirty laptops in a room, each running its own PDS, each federating locally. The teacher’s laptop aggregates student work through ATPProto subscriptions. No cloud dependency. No internet required. The room is the network.

10. CONCLUSION

Aesthetic Computer already runs a PDS, mints DIDs, syncs content to ATPProto records, and publishes custom lexicons. The only piece missing is letting users authenticate through that infrastructure instead of routing through Auth0. The migration is not a rewrite—it is the removal of a workaround.

The phased approach (ATProto as secondary sign-in → handle bridging → identity linking → ATPProto-primary) ensures no existing user is disrupted. The end state: a creative computing platform where your handle is a cryptographic identity, your content lives on a server you control, and signing in means proving you own your keys—not trusting a third party to vouch for you.

The PDS is already running. The DIDs are already minted. The lexicons are already published. It is time to let users sign in through the front door.

Reference Links

AT Protocol Specifications:

- <https://atproto.com/specs> — Full protocol specification
- <https://atproto.com/specs/oauth> — OAuth specification
- <https://atproto.com/specs/handle> — Handle resolution
- <https://atproto.com/specs/cryptography> — Cryptographic methods
- <https://web.plc.directory/spec/v0.1/did-plc> — DID PLC specification
- <https://atproto.com/guides/lexicon> — Lexicon schema system
- <https://atproto.com/guides/oauth-patterns> — OAuth implementation patterns

Implementation Guides:

- <https://docs.bsky.app/blog/oauth-atproto> — Building ATProto OAuth apps
- <https://docs.bsky.app/docs/advanced-guides/resolving-identities> — Identity resolution
- <https://docs.bsky.app/docs/advanced-guides/oauth-client> — OAuth client guide

NPM Packages:

- `@atproto/oauth-client-node` — Node.js OAuth client
- `@atproto/oauth-client-browser` — Browser OAuth client
- `@atproto/api` — TypeScript XRPC client
- `@atproto/identity` — DID/handle resolution
- `@atcute/oauth-browser-client` — Lightweight alternative

Reference Implementations:

- <https://github.com/pilcrowonpaper/atproto-oauth-example> — Astro OAuth example
- <https://github.com/bluesky-social/atproto> — Official AT-Proto monorepo
- <https://standard.site/docs/introduction/> — Standard.site shared lexicons

Applications Using ATProto Auth:

- pckt.blog — Blogging on the open social web
- Leaflet.pub — Long-form publishing
- Offprint.app — Collaborative writing

IETF Standards:

- RFC 9449 — DPOP (Demonstrating Proof of Possession)
- RFC 7636 — PKCE (Proof Key for Code Exchange)
- RFC 9126 — PAR (Pushed Authorization Requests)

References

Auth0 by Okta. Auth0 Single Page App SDK. <https://auth0.com/docs/libraries/auth0-single-page-app-sdk>, 2024. JavaScript SDK for browser-based OAuth flows.

Bluesky PBC. At protocol cryptography specification. <https://atproto.com/specs/cryptography>, 2024a. P-256 and K-256 elliptic curve signing.

Bluesky PBC. Did plc specification v0.1. <https://web.plc.directory/spec/v0.1/did-plc>, 2024b. Decentralized Identifiers for AT Protocol.

Bluesky PBC. At protocol handle specification. <https://atproto.com/specs/handle>, 2024c. Handle resolution via DNS TXT and HTTPS well-known.

Bluesky PBC. At protocol oauth specification. <https://atproto.com/specs/oauth>, 2024d. OAuth 2.1 with PKCE, DPOP, and PAR for decentralized authentication.

Bluesky PBC. At protocol specification. <https://atproto.com/specs>, 2024e. Decentralized social networking protocol.

Bluesky PBC. @atproto/oauth-client-node. <https://www.npmjs.com/package/@atproto/oauth-client-node>, 2024f. Node.js AT Protocol OAuth client library.

Daniel Fett, Brian Campbell, John Bradley, Torsten Lodderstedt, Michael Jones, and David Waite. RFC 9449: OAuth 2.0 Demonstrating Proof of Possession (DPOP). <https://datatracker.ietf.org/doc/html/rfc9449>, 2023. IETF standard for binding tokens to client key pairs.

Ivan Illich. *Tools for Conviviality*. Harper & Row, New York, 1973.

@jeffrey. Aesthetic computer '26: A mobile-first runtime for creative computing, 2026a. Companion paper describing the AC platform.

@jeffrey. Ac native os '26: A bare-metal creative computing operating system, 2026b. Companion paper describing the AC Native OS.

Torsten Lodderstedt, Brian Campbell, Nat Sakimura, Dave Tonge, and Daniel Fett. RFC 9126: OAuth 2.0 Pushed Authorization Requests. <https://datatracker.ietf.org/doc/html/rfc9126>, 2021. Pushed Authorization Requests for OAuth.

Ted Nelson. *Computer Lib / Dream Machines*. Self-published, 1974. Revised edition 1987, Tempus Books/Microsoft Press.

pckt.blog. Blogging on the open social web and more exciting features. <https://devlog.pckt.blog/blogging-on-the-open-social-web-and-more-exciting-features-g9x55y6>, 2025. Development journal on ATProto blog integration.

Nat Sakimura, John Bradley, and Naveen Agarwal. RFC 7636: Proof Key for Code Exchange by OAuth Public Clients. <https://datatracker.ietf.org/doc/html/rfc7636>, 2015. PKCE for OAuth authorization code flow.

Standard.site. Standard site: Open blog publishing on at protocol. <https://standard.site/docs/introduction/>, 2025. Shared lexicons for blog content portability across ATProto.

W3C. Decentralized Identifiers (DIDs) v1.0. <https://www.w3.org/TR/did-core/>, 2022. W3C Recommendation for decentralized identifiers.